

ວຽກມອບໝາຍ 11

ວຽກມອບໝາຍ ບົດທີ 11: ພື້ນຖານຄວາມປອດໄພຂອງຊອບແວ

1. ການວິເຄາະແນວຄິດ "Shift Left" (Shift Left Approach Analysis)

- **ຄໍາຖາມ:** ໃນການພັດທະນາຊອບແວແບບດັ່ງເດີມ, "ການທົດສອບຄວາມປອດໄພ"

ມັກຈະຖືກເຮັດໃນຂັ້ນຕອນສຸດທ້າຍກ່ອນການປ່ອຍລະບົບ
(Deploy).

- ກ. ວິທີການແບບດັ່ງເດີມນີ້ ມີຂໍ້ເສຍ ຫຼື ຄວາມສ່ຽງແນວໃດແດ່? (ຍົກມາຢ່າງໜ້ອຍ 2 ຂໍ້).
- ຂ. ແນວຄິດ "Shift Left" ໃນ SSDLC ເຂົ້າມາແກ້ໄຂບັນຫານີ້ແນວໃດ? ຈົ່ງອະທິບາຍຄວາມໝາຍຂອງຄຳວ່າ "Shift Left" ຕາມຄວາມເຂົ້າໃຈຂອງທ່ານ.

2. ການສານຄວາມປອດໄພເຂົ້າໃນ SDLC (Integrating Security into SDLC)

- **ຄໍາຖາມ:** ເພື່ອໃຫ້ເກີດ SSDLC ທີ່ແທ້ຈິງ, ເຮົາຕ້ອງມີກົດຈະກຳດ້ານຄວາມປອດໄພໃນທຸກຂັ້ນຕອນ. ຈົ່ງລະບຸ ແລະ ອະທິບາຍກົດຈະກຳດ້ານຄວາມປອດໄພ 1 ຢ່າງ ທີ່ຄວນເຮັດໃນຂັ້ນຕອນດັ່ງຕໍ່ໄປນີ້:

- ກ. ຂັ້ນຕອນ Design (ການອອກແບບ): (ຕົວຢ່າງ: ຄວນເຮັດກົດຈະກຳຫຍັງ ເພື່ອຄົ້ນຫາຊ່ອງໂຫວ່ກ່ອນການຂຽນໂຄດ?)
- ຂ. ຂັ້ນຕອນ Development (ການພັດທະນາ): (ຕົວຢ່າງ: ເຄື່ອງມື ຫຼື ແນວທາງປະຕິບັດໃດ ທີ່ຊ່ວຍໃຫ້ນັກພັດທະນາຂຽນໂຄດໄດ້ປອດໄພຂຶ້ນ?)

3. ການວິເຄາະຊ່ອງໂຫວ່ OWASP Top 10 (Vulnerability Analysis)

- **ຄໍາຖາມ:** ຈົ່ງອ່ານສະຖານະການ 2 ກໍລະນີຕໍ່ໄປນີ້ ແລ້ວລະບຸວ່າ ມັນກົງກັບຊ່ອງໂຫວ່ໃດໃນ OWASP Top 10, ພ້ອມທັງບອກວິທີປ້ອງກັນ.

- ກ. ສະຖານະການ A: ທ້າວ ສິມສິ ເຂົ້າສູ່ລະບົບທະນາຄານອອນລາຍຂອງຕົນເອງ.

ລາວສັງເກດເຫັນ URL ຂຽນວ່າ bank.com/account?id=1001.

ລາວລອງປ່ຽນຕົວເລກເປັນ id=1005 ແລ້ວກົດ Enter,

ປາກົດວ່າລາວສາມາດເຫັນຍອດເງິນໃນບັນຊີຂອງຄົນອື່ນໄດ້.

- ຊ່ອງໂຫວ່ນີ້ເອີ້ນວ່າຫຍັງ? ແລະ ຈະປ້ອງກັນໄດ້ແນວໃດ?

- ຂ. ສະຖານະການ B: ແຮກເກີພິມຄຳວ່າ ' OR '1'='1 ລົງໃນຊ່ອງໃສ່ຊື່ຜູ້ໃຊ້

(Username) ແລະ ລະຫັດຜ່ານ ໃນໜ້າຈໍລ່ອກອິນ. ລະບົບປະມວນຜົນຜິດພາດ ແລະ

ອະນຸຍາດໃຫ້ແຮກເກີເຂົ້າສູ່ລະບົບໄດ້ໃນຖານະຜູ້ເບິ່ງແຍງລະບົບ

(Admin).

- ຊ່ອງໂຫວ່ນີ້ເອີ້ນວ່າຫຍັງ? ແລະ ຈະປ້ອງກັນໃນລະດັບໂຄດໄດ້ແນວໃດ?

4. ຫຼັກການຂຽນໂຄດຢ່າງປອດໄພ (Secure Coding Principles)

- **ຄໍາຖາມ:** ຈົ່ງອະທິບາຍຫຼັກການຂຽນໂຄດຢ່າງປອດໄພ 2 ຂໍ້ຕໍ່ໄປນີ້ ພ້ອມທັງຍົກຕົວຢ່າງປະກອບໃຫ້ເຫັນພາບ:

- ກ. ຫຼັກການ "Least Privilege" (ການໃຫ້ສິດໜ້ອຍທີ່ສຸດ): ຈົ່ງອະທິບາຍຄວາມໝາຍ ແລະ ຍົກຕົວຢ່າງການນຳໃຊ້ຫຼັກການນີ້ໃນການເຊື່ອມຕໍ່ລະບົບຂອງທ່ານເຂົ້າກັບຖານຂໍ້ມູນ(Database).
- ຂ. ຫຼັກການ "Defense in Depth" (ການປ້ອງກັນເຊິ່ງເລິກ): ຈົ່ງອະທິບາຍຄວາມໝາຍ (ສາມາດໃຊ້ການປຽບທຽບກັບ "ປາສາດ" ຫຼື "ຫົວຫອມ" ໄດ້) ແລະ ຍົກຕົວຢ່າງການສ້າງຊັ້ນປ້ອງກັນຫຼາຍໆຊັ້ນ ສຳລັບໜ້າຈໍ Admin.

5. ການສະທ້ອນຄືນຕົນເອງ: Mindset ດ້ານຄວາມປອດໄພ (Self-Reflection)

- ຄໍາຖາມ: ໃນບົດຮຽນມີຄໍາກ່າວໜຶ່ງທີ່ສໍາຄັນຫຼາຍຄື: "ຢ່າໄວ້ວາງໃຈ Input ຈາກຜູ້ໃຊ້ຢ່າງເດັດຂາດ (Never Trust User Input)".

- ກ. ໃນຖານະທີ່ທ່ານຈະກາຍເປັນນັກພັດທະນາຊອບແວໃນອະນາຄົດ, ປະໂຫຍກນີ້ເຮັດໃຫ້ທ່ານປ່ຽນແປງມຸມມອງໃນເວລາທີ່ທ່ານກໍາລັງຈະຂຽນໂຄດຮັບຂໍ້ມູນຈາກຟອມ (Form) ຫຼື URL ແນວໃດແດ່?
- ຂ. ທ່ານຄິດວ່າ "ຄວາມປອດໄພ" ຄວນເປັນຄວາມຮັບຜິດຊອບຂອງທີມ Security ພຽງຝ່າຍດຽວ ຫຼື ເປັນຄວາມຮັບຜິດຊອບຂອງທຸກຄົນໃນທີມພັດທະນາ? ຈົ່ງໃຫ້ເຫດຜົນ.